PIPELINE SEGURO

Checklist de seguridad para workflows

Repásalo antes de hacer push de cualquier archivo en `.github/workflows/`. Si una casilla queda vacía, el pipeline no está terminado.

Todo workflow

- [ ] **Secretos aparte:** en Settings › Secrets and variables › Actions. Nunca en el código ni en el YAML.
- [ ] **Permisos mínimos:** hay un bloque `permissions:` y parte con `contents: read`.
- [ ] **Versión fija:** cada acción con versión (`checkout@v6`, `setup-dotnet@v5`), nunca `@main`. Lo más estricto: el SHA completo.
- [ ] **Logs limpios:** ningún `echo` de un secreto, ni siquiera transformado (base64, subcadenas).
- [ ] **Forks sin secretos:** sabes que un PR desde un fork no recibe tus secretos.
- [ ] **Con límite:** cada job tiene `timeout-minutes`.

Además, si el workflow usa a Claude

- [ ] La Claude GitHub App está instalada en el repo.
- [ ] **La credencial es un secreto:** `CLAUDE_CODE_OAUTH_TOKEN`, el token de tu Claude Pro (`claude setup-token`). Gasta tu cuota y no se comparte.
- [ ] `permissions` son las del ejemplo oficial y nada más: `contents`, `pull-requests`, `issues`, `actions: read` e `id-token: write`.
- [ ] `claude_args` limita las vueltas: `--max-turns 5`.
- [ ] Si Claude solo debe diagnosticar, `--disallowedTools "Edit,Write"` le quita las herramientas de edición.
- [ ] Hay `concurrency`: una ejecución a la vez por hilo.
- [ ] Sabes que solo quien tiene escritura en el repo puede disparar a `@claude`.

ASÍ NO · ASÍ SÍ

ASÍ NO

```
- uses: anthropics/claude-code-action@v1
  with:
    claude_code_oauth_token: "pega-aquí-tu-token"
- run: echo "Token: $TOKEN"
```

ASÍ SÍ

```
- uses: anthropics/claude-code-action@v1
  with:
    claude_code_oauth_token: ${{ secrets.CLAUDE_CODE_OAUTH_TOKEN }}
# sin echo del secreto
```

¿Subiste un secreto por error? Rótalo de inmediato: genera uno nuevo (`claude setup-token`), actualiza el secreto en GitHub e invalida el anterior. Borrar el archivo no basta, porque git guarda el historial.

FUENTES

GitHub Docs · Using secrets in GitHub Actions
docs.github.com/en/actions/security-guides/using-secrets-in-github-actions · consultado el 10-nov-2026

Claude Code Docs · GitHub Actions
code.claude.com/docs/en/github-actions · consultado el 10-nov-2026